

IndieHackers launch post — firm-bot v0.1

Mine-FNL

IndieHackers launch post — firm-bot v0.1

First-person, building-in-public voice. Post it as written; the specific origin story and the honest "hard parts" sections are the parts IndieHackers readers engage with most.

Title

Building firm-bot — local-first RAG for legal/audit (because cloud RAG can't satisfy every compliance posture)

Body

I just open-sourced firm-bot, a local-first RAG chatbot builder for professional services firms (legal, audit, consultancy). The pitch: drop your PDFs/EMLs/DOCX into a per-firm folder, get a chat endpoint with citations on every claim. Nothing leaves the box — no cloud calls, no telemetry, no vendor.

Why I built it

A firm I was working with needed to put their contracts in a vector store. In-house compliance said no — the cloud vendor was on the chain of custody, the contracts were privileged. Existing options were all cloud. So I built the local-first alternative.

The chunker turned out to be the actual hard problem. Contracts don't follow "Section 1, Section 2" — they have Article + Title Case headings (WHEREAS, RECITALS), indented exhibits, sectionless prose. The structure-aware chunker (Article §, Section, Title Case, WHEREAS, numbered clauses) moved precision@k from 0.462 to 0.538 on the CUAD subset. The rest of the system grew around it.

What's hard

Four things, honestly:

- 1. The chunker regex cascade took three iterations.** First pass over-matched — "Article" appeared in body text and got cut. Second pass under-matched — missed Title Case headings in all-caps contracts. Third pass added a "must be near the start of a line" heuristic. Still rule-based; a learned approach would generalise better, but rule-based is auditable — a feature when the buyer is in-house legal.
- 2. The LLM-as-judge over-flags at 7B.** Catches things it shouldn't, misses things it should. At 14B+ it gets materially better. The guard is advisory by default — surfaces warnings without blocking responses.
- 3. Citation-required prompts reduce fabrication but don't eliminate it.** The model still invents [file:page] markers that don't exist in the retrieved context. Mitigation is human-in-the-loop: the UI shows citations, the user clicks through.
- 4. Per-firm filesystem isolation is fiddly.** One Chroma collection + one BM25 index + one document directory per firm. Works, not elegant. We considered a separate process per firm but rejected it for operational simplicity. The on-disk footprint is repetitive.

What I'd love feedback on

- 1. Is the citation-required pattern interesting as a default, or should it be opt-in?** We picked enforcement because the failure mode is silent. But I see the argument for opt-in: it changes the tone.
- 2. Anyone else running into "vendor RAG doesn't satisfy our compliance review"?** Self-host, wait for a vendor with the right DPA, or decide the risk was acceptable? I'd especially like to hear from teams who chose a hybrid — cloud for general, local for the privileged corpus.

3. **How are you thinking about prompt injection in your RAG systems?** Open problem. Our position is that mitigation is application-layer (input classifiers, output filtering, instruction-defence prompts), not product-layer. What's working for other teams?

Revenue / sustainability

firm-bot is MIT-licensed open source. No paid tier. No SaaS. I'm considering consulting + support contracts for firms that want help deploying it — the v0.1 install is `git clone && firm-bot serve`, but the production rollout (auth, multi-user, observability, audit trail export) is real work. It's not currently revenue-generating. I'd rather have a working tool that gets used than a paid tool that nobody touches.

Tech stack

- **FastAPI + Starlette** — middleware fits the security story (per-IP rate limit, body cap, CORS) cleanly.
- **Chroma (embedded)** — simplest path to per-firm collections without a separate server. Server-mode available for multi-worker.
- **BM25 (rank-bm25)** — lexical baseline for the hybrid retriever.
- **sentence-transformers / fastembed** — local embedding, swap-in model interface (default `all-MiniLM-L6-v2`).
- **Ollama** — local LLM runtime, OpenAI-compatible API, runs on macOS / Linux / CUDA / Metal.
- **Python 3.11+** — type hints, `mypy --strict`, `ruff` clean. CI-enforced.
- **Optional: Prometheus** — opt-in via `pip install firm-bot[observability]`.

Link + next steps

github.com/Mine-FNL/firm-bot — MIT, 129 tests, 74.47% coverage, `ruff + mypy --strict` clean.

Reproduce the benchmarks locally:

```
git clone https://github.com/Mine-FNL/firm-bot
cd firm-bot
pip install -e ".[dev,observability]"
python3 -m eval.cuad --chunker structure_aware
python3 -m eval.load --total 200 --concurrency 16
```

Next: v0.2 brings OAuth2/OIDC middleware and per-user query history. v0.3 benchmarks 70B-class local models. The full roadmap is in `WHITEPAPER.md` §9 and is shaped by what people actually deploy.

Happy to answer any questions in the comments.